

Vulnerability Management Policy

Langate Group

Purpose

The purpose of this policy is to outline the requirements for (1) all product systems to be scanned for vulnerabilities at least annually and (2) all vulnerability findings to be reported, tagged, and tracked to resolution in accordance with the SLAs defined herein. Records of findings must be retained for at least 5 years.

Roles and Responsibilities

- **IT Manager** is responsible for policy implementation.
- **ISMS manager** is responsible for updating, reviewing, and maintaining this policy.

Policy

Information Systems Audit

The following guidelines will be observed for setting information systems audit controls:

- Audit requirements for access to systems and data should be agreed with appropriate management.
- Scope of technical audit tests should be agreed and controlled.
- Audit tests should be limited to read-only access to software and data.
- Access other than read-only should only be allowed for isolated copies of system files, which should be erased when the audit is completed or given appropriate protection if there is an obligation to keep such files under audit documentation requirements.
- Requirements for special or additional processing should be identified and agreed.
- Audit tests that could affect system availability should be run outside business hours.
- All access should be monitored and logged to produce a reference trail.

Vulnerability Scanning and Infrastructure Security Testing

The scanning and identification of Langate Group's system vulnerabilities are performed by:

- Microsoft 365 Security services
- Microsoft Intune
- MS Defender
- Drata security agent
- KnowBe4
- Manually

Penetration Testing

Penetration testing is performed regularly by a certified penetration tester on Langate Group's security team, an independent third party, or automated scanning tools.

The IT manager analyzes the findings from a vulnerability scan and/or penetration test and reports them using the process defined in the next section.

Security Findings Reporting, Tracking, and Remediation

Langate Group follows a simple vulnerability tracking process using YouTrack. Records of findings are retained for 5 years.

Reporting a Finding

- Upon identification of a vulnerability (including software, system, or process), a ticket is created for the appropriate team in YouTrack.
- The description of the finding should include details, excluding confidential information, and a link to the source.
- The finding is given a priority level in YouTrack.

Priority/Severity Ratings and Service Level Agreements

In an effort to quickly remediate security vulnerabilities, the following timelines have been put in place to address vulnerabilities:

Priority Level	SLA	Definition	Examples
Critical	24 hours	Vulnerabilities that cause a privilege escalation on the platform from unprivileged to admin, allows remote code execution, financial theft, unauthorized access to/ extraction of sensitive data, etc.	Vulnerabilities that result in Remote Code Execution such as Vertical Authentication bypass, SSRF, XXE, SQL Injection, User authentication bypass
High	72 hours	Vulnerabilities that affect the security of the platform including the processes it supports.	Lateral authentication bypass, Stored XSS, some CSRF depending on impact
Medium	7 days	Vulnerabilities that affect multiple users, and require little or no user interaction to trigger	Reflective XSS, Direct object reference, URL Redirect, some CSRF depending on impact
Low	30 days	Issues that affect singular users and require interaction or significant prerequisites (MitM) to trigger.	Common flaws, Debug information, Mixed Content

In the case that a severity rating and/or priority level is updated after a vulnerability finding was originally created, the SLA is updated as follows:

- Priority upgrade: reset SLA from the time of escalation.
- Priority downgrade: SLA time remains the same from the time the finding is created/identified.

Resolving a Finding

- The Finding should be assigned to the owner responsible for the system or software package.
- All findings should be addressed according to the established SLA.
- No software should be deployed to production with unresolved CRITICAL or HIGH findings unless an Exception is in place (see below).
- A finding may be resolved by
 - providing a valid fix/mitigation
 - determining as a false positive
 - documenting an approved exception

Closing a Finding

- The assignee should provide a valid resolution (see above) and add a comment to the finding.
- The finding should be re-assigned to the Reporter or a member of the security team for validation.
- Upon validation, the finding can be marked as Done (closed) by the Reporter.
- Before the finding can be marked as closed by the reporter, the fix must be deployed to a development environment and have a targeted release date for deploying to production noted on the ticket.

Exceptions

- An Exception may be requested when a viable or direct fix to a vulnerability is not available. For example, a version of the package that contains the fix is not supported on the particular operating system in use.
- An alternative solution (a.k.a. compensating control) must be in place to address the original vulnerability such that the risk is mitigated. The compensating control may be technical, a process, or a combination of both.
- An exception must be opened as a YouTrack ticket.
- The Exception Issue must reference the original Finding by adding an Issue Link to the Finding issue.
- Each Exception must be reviewed and approved by the ISMS Manager and the impacted asset owner.

Policy version history

 Policy details

Policy name	Renewal date
Vulnerability Management Policy	May 5, 2027
Description	
The Vulnerability Management Policy outlines the company's procedures to uncover, classify, track, and remediate security vulnerabilities.	

 Version history

Version 1					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
July 15, 2024	April 14, 2025	April 14, 2025	Eugene Skubach	Eugene Skubach	Eugene Skubach
Version 1.1					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
May 6, 2025	No approval required	May 6, 2025	Eugene Skubach	-	Eugene Skubach
Version 1.2					
Explanation of changes					
'Revision History' section has been removed					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
September 26, 2025	No approval required	September 26, 2025	Eugene Skubach	-	Eugene Skubach
Version 2					

Explanation of changes

Changed Microsoft Teams to YouTrack

Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
May 5, 2026	May 5, 2026	May 5, 2026	Eugene Skubach	Eugene Skubach	Eugene Skubach

Version 2.1

Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
May 5, 2026	No approval required	May 5, 2026	Eugene Skubach	-	Eugene Skubach